Web Application Penetration Test Report

Acme Corp customer portal (acme.corp)

PREPARED BY
Farhan Hussain, Penetration Tester (CPENT)

REPORT DATE
3 November 2026

TEST WINDOW
Sample engagement, 3 days

CLASSIFICATION
Sample for demonstration. Not a real client.

TARGET
acme.corp, 10.10.11.42 (lab environment)

METHOD
Black box, OWASP Top 10, PTES-aligned, CVSS v3.1

> **About this document.** This is a sample report written to show how I structure findings, evidence and remediation advice. The target, company and data are fictional and were built in a lab. The format and level of detail match how I report real work.

1. Executive summary

Acme Corp asked for an assessment of its customer portal. The testing found that an unauthenticated attacker could read internal data and obtain full administrative control of the server by chaining five weaknesses. No single step required advanced tooling.

The most serious issue is an SQL injection in the report export function, which exposes user records and password hashes. A leaked notes file and a weak hashing scheme made the compromise faster. We recommend fixing the Critical and High items within 7 days.

1	2	1	1
CRITICAL	HIGH	MEDIUM	LOW

2. Scope and method

- **In scope:** acme.corp web application and host 10.10.11.42 (ports 22, 80, 31337).
- **Out of scope:** denial of service, social engineering, third-party services.
- **Phases:** reconnaissance, enumeration, exploitation, privilege escalation, reporting.
- **Tools:** Nmap, curl, Burp Suite, SQLMap, Hashcat.

3. Findings summary

ID	FINDING	SEVERITY	CVSS
F-01	SQL injection in /export (id parameter)	CRITICAL	9.8
F-02	Credentials exposed in a public notes file	HIGH	7.5
F-03	Sudo rule allows root shell via find	HIGH	7.8
F-04	Unsalted MD5 password hashes	MEDIUM	5.9
F-05	Verbose server banners and error messages	LOW	3.7

4. Attack path

Public notes.txt → Admin login → SQLi dump of hashes → MD5 cracked offline → SSH as deploy → sudo find to root

5. Detailed findings

F-01 SQL injection in the export function CRITICAL

Affected: GET /export?id= **CVSS:** 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H) **Reference:** OWASP A03:2021, CWE-89

Description. The id parameter is concatenated into a SQL query without parameterisation. A single quote changes the query logic and returns every row.

Impact. An attacker can read all user records, including usernames and password hashes, and can pivot to account takeover.

Evidence.

```
GET /export?id=1' OR '1'='1 HTTP/1.1
Host: acme.corp
X-Key: [redacted]

HTTP/1.1 200 OK
id | user   | hash
 1 | root   | 4ece57a6...[redacted]
 2 | deploy | 4ca7c5c2...[redacted]
```

Steps to reproduce. 1) Send the request above. 2) Observe that all rows are returned instead of one. 3) Confirm with SQLMap using --batch --dbs.

Remediation. Use parameterised queries or an ORM. Validate id as an integer. Run the application with a least-privilege database account. Add a WAF rule as defence in depth, not as the fix.

F-02 Credentials in a public notes file HIGH

Affected: GET /notes.txt **CVSS:** 7.5 **Reference:** OWASP A05:2021, CWE-538

A developer note, referenced in an HTML comment on the home page, contains the admin username and password in clear text. Remove the file, rotate the credentials and add a pre-release check that scans for secrets and TODO comments.

F-03 Over-permissive sudo rule HIGH

Affected: sudoers entry for user deploy **CVSS:** 7.8 **Reference:** CWE-269

The deploy user may run /usr/bin/find as root without a password. find can execute commands, so this gives an immediate root shell.

```
$ sudo -l
(root) NOPASSWD: /usr/bin/find
$ sudo find . -exec /bin/sh \; -quit
# whoami
root
```

Remediation. Remove the rule or restrict it to a fixed wrapper script. Review all NOPASSWD entries against GTFOBins.

F-04 Unsalted MD5 password hashes MEDIUM

Passwords are stored as plain MD5. A user hash was recovered with a common wordlist in under a second. **Remediation:** migrate to Argon2id or bcrypt with per-user salts, and force a password reset after migration.

F-05 Verbose banners and errors LOW

Server version banners and stack traces help an attacker choose exploits. **Remediation:** hide version strings and return generic error pages.

6. Remediation roadmap

PRIORITY	ACTION	TIMEFRAME
1	Fix F-01 with parameterised queries; remove F-02 file and rotate secrets	7 days
2	Remove or restrict the sudo rule (F-03)	7 days
3	Migrate password hashing (F-04) and force resets	30 days
4	Harden banners and error handling (F-05)	30 days
5	Add secret scanning and security tests to the release pipeline; retest	60 days

7. Conclusion

The application was compromised end to end using only low-skill techniques, which shows how small configuration mistakes combine. The fixes are straightforward and mostly low-cost. After remediation, a retest is recommended to confirm every finding is closed.

> **Severity scale.** Critical 9.0 to 10, High 7.0 to 8.9, Medium 4.0 to 6.9, Low 0.1 to 3.9 (CVSS v3.1). This sample is fictional and was built from lab practice. Real engagements follow a signed scope and rules of engagement.